

Cybersecurity, SOC2 & ISO 27001 Compliance Standards

Security Classification: Restricted | **Compliance Officer:** Chief Information Security Officer (CISO)

1. Data Encryption and Key Management

All customer data in transit must be encrypted using **TLS 1.3** (minimum fallback TLS 1.2). Data at rest across all SQLite shards, ChromaDB vector stores, and object buckets is encrypted using **AES-256** encryption keys managed via Google Cloud KMS with annual automatic key rotation.

2. Access Control and Multi-Factor Authentication (MFA)

Access to production environments and databases requires Hardware-backed FIDO2 MFA keys or Okta Verify with biometric verification. Role-Based Access Control (RBAC) follows the Principle of Least Privilege (PoLP) and is audited quarterly by the internal security team.

3. Incident Response Protocol & Escalation SLA

Severity Level	Description	Escalation Target	Customer Notice SLA
Severity 1 (Critical)	Data breach or complete outage	Immediate (CISO & On-Call)	< 2 Hours
Severity 2 (High)	Partial service disruption	< 15 Minutes	< 6 Hours
Severity 3 (Medium)	Isolated non-critical bug	< 1 Hour	Next Release Notes
Severity 4 (Low)	Cosmetic or minor documentation issue	< 24 Hours	Quarterly Patch

4. Data Retention and Deletion SLA

Upon enterprise contract termination, customer data and embedded vectors are securely erased within **30 calendar days** using cryptographic erasure (DoD 5220.22-M compliant).